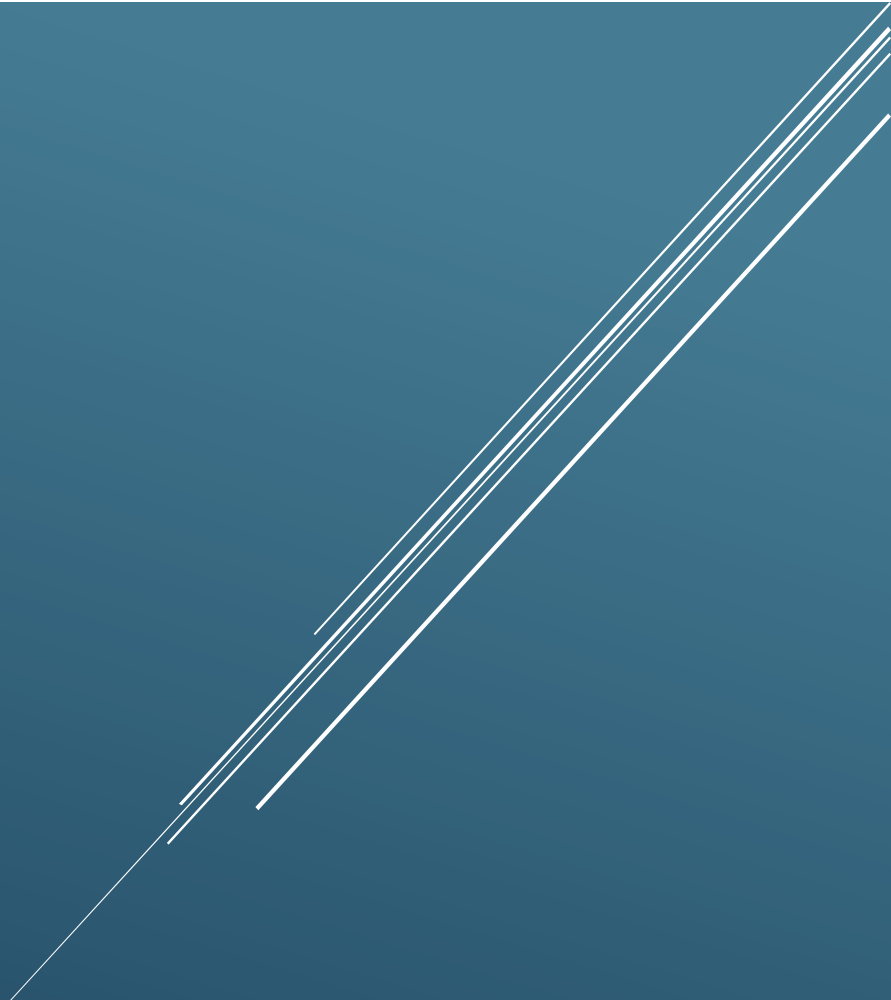




ΤΕΧΝΙΚΕΣ ΚΑΙ ΕΡΓΑΛΕΙΑ ΔΥΝΑΜΙΚΗΣ ΑΝΑΛΥΣΗΣ ΚΑΚΟΒΟΥΛΟΥ ΛΟΓΙΣΜΙΚΟΥ

Όνομα: Κουμεντέας Βασίλης- ΑΜ: 1083637

Contents

Εισαγωγή	2
Τεχνικές	2
1. Sandboxing.....	2
2. Παρακολούθηση Δικτυακής Κίνησης.....	4
3. Παρακολούθηση Αλλαγών στο Σύστημα Αρχείων	6
4. Ανίχνευση Κλήσεων API και Χρήσης Εντολών.....	7
5. Ανάλυση Συμπεριφοράς Μνήμης	9
6. Reverse Debugging (Ανάλυση Αντίστροφης Εκτέλεσης)	12
Εργαλεία.....	14
1. Cuckoo Sandbox	14
2. Process Monitor (ProcMon)	15
3. Wireshark	16
4. Process Explorer	17
5. Regshot	18
6. ApateDNS.....	20
7. OllyDbg.....	21
8. INetSim.....	21
9. FakeNet-NG.....	23
10. Burp Suite.....	23

Εισαγωγή

Η δυναμική ανάλυση κακόβουλου λογισμικού, με λίγα λόγια είναι η εκτέλεση ενός κακόβουλου λογισμικού σε ελεγχόμενο περιβάλλον, προκειμένου να παρατηρηθεί η συμπεριφορά του και να εξαχθούν συμπεράσματα για τις δυνατότητές του και τις επιπτώσεις του. Αυτό δίνει τη δυνατότητα στους τεχνικούς ασφάλειας, να δημιουργήσουν ή να εντοπίσουν τα εργαλεία που χρειάζονται για να αντιμετωπίσουν μια τέτοια επίθεση σε πραγματικό χρόνο. Είναι δηλαδή μια προσομοίωση.

Ο σκοπός αυτής της εργασίας είναι να αναλύσουμε τεχνικές δυναμικής ανάλυσης κακόβουλων λογισμικών και να περιγράψουμε αναλυτικά κάποια εργαλεία που χρησιμοποιούμε για την διεκπεραίωση αυτών των τεχνικών.

Τεχνικές

Υπάρχουν διάφορες τεχνικές που μπορούμε να ακολουθήσουμε, πάρα πολλές για να της αναλύσουμε στην παρούσα εργασία. Ωστόσο, θα αναλύσουμε μερικές από τις πιο διαδεδομένες:

1. Sandboxing

Η δυναμική ανάλυση κακόβουλου λογισμικού με sandboxing είναι μια τεχνική στην οποία εκτελούμε αρχεία με πιθανό κακόβουλο λογισμικό σε ένα ελεγχόμενο περιβάλλον (sandbox) για να παρατηρήσει τη συμπεριφορά τους. Το sandbox εμποδίζει το κακόβουλο λογισμικό να μολύνει το πραγματικό σύστημα, επιτρέποντας στους αναλυτές να μελετήσουν τις ενέργειές του με ασφάλεια

Αυτή η μέθοδος χρησιμοποιείται, για παράδειγμα, από εταιρείες antivirus για να αναλύσουν κακόβουλο λογισμικό και να προσαρμόζουν τα προϊόντα τους καλύτερα. Ένα δεύτερο παράδειγμα είναι για αγορές εφαρμογών που κάνουν εταιρείες από τους προγραμματιστές που τις υποβάλλουν.

Αξιοσημείωτο είναι όμως το γεγονός, όπου το κακόβουλο λογισμικό μπορεί να προσπαθήσει να αποφύγει την ανίχνευση μέσα σε ένα sandbox, ελέγχοντας για χαρακτηριστικά που υποδηλώνουν ότι βρίσκεται σε εικονικό/τεχνητό περιβάλλον. Να σημειωθεί ότι το sandboxing ουσιαστικά καλύπτει όλες τις τεχνικές που θα αναλύσουμε παρακάτω, διότι είναι μια πιο «γενική» μέθοδος αυτή.

Η τεχνική αυτή έχει τα παρακάτω βήματα:

Βήμα 1. Δημιουργία Sandbox: Χρησιμοποιείται ένα εικονικό μηχανήμα ή εξομοιωτής για τη δημιουργία του sandbox.

Βήμα 2. Εκτέλεση του Δείγματος: Το ύποπτο αρχείο εκτελείται μέσα στο sandbox.

Βήμα 3. Παρακολούθηση Δραστηριότητας: Εργαλεία παρακολούθησης καταγράφουν τις ενέργειες του αρχείου, όπως:

- Κλήσεις Συστήματος
- Πρόσβαση σε Αρχεία και Μνήμη
- Δραστηριότητα Δικτύου
- Αλλαγές στο μητρώο

Βήμα 4. Ανάλυση των Δεδομένων: Οι αναλυτές εξετάζουν τα συλλεγμένα δεδομένα για να κατανοήσουν τη συμπεριφορά του λογισμικού και να προσδιορίσουν εάν είναι κακόβουλο.

Πλεονεκτήματα τεχνικής:

- Ασφάλεια: Το sandbox προστατεύει το πραγματικό σύστημα από μόλυνση.
- Ανάλυση σε Βάθος: Παρέχει λεπτομερή εικόνα για τις ενέργειες του κακόβουλου λογισμικού.
- Εντοπισμός Νέων Απειλών: Μπορεί να εντοπίσει κακόβουλο λογισμικό που χρησιμοποιεί άγνωστες τεχνικές.

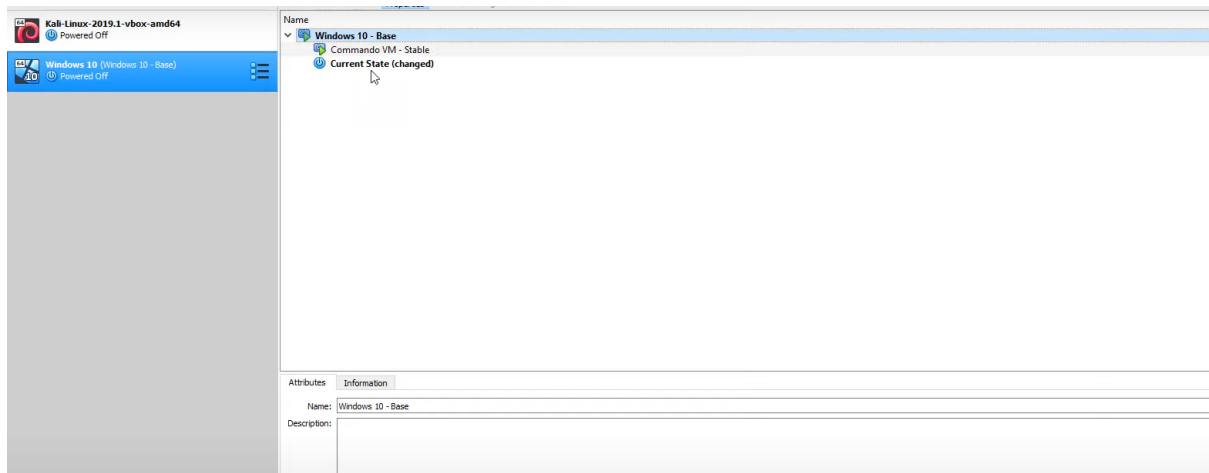
Προκλήσεις τεχνικής:

- Αντι-Sandboxing Τεχνικές: Το κακόβουλο λογισμικό μπορεί να ανιχνεύσει το sandbox και να αλλάξει τη συμπεριφορά του (όπως αναφέρθηκε προηγουμένως).
- Πλοκές: Το κακόβουλο λογισμικό μπορεί να είναι κρυπτογραφημένο ή συσκευασμένο, καθιστώντας δύσκολη την ανάλυση.
- Περιορισμένη προσομοίωση: Το sandbox μπορεί να μην αντικατοπτρίζει πλήρως το πραγματικό περιβάλλον ενός χρήστη.

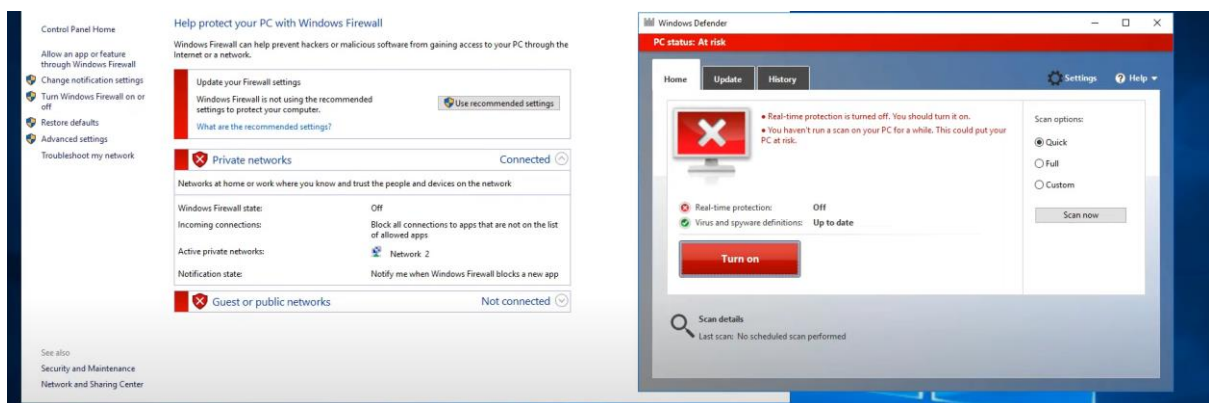
Παραδείγματα Sandboxing Εργαλείων:

- Cuckoo Sandbox
- CWSandbox
- VMWare Workstation
- TEMU (BitBlaze project)
- QEMU

Παρακάτω βλέπουμε εικόνες δημιουργίας ενός εικονικού περιβάλλοντος που ετοιμάζεται για ανάλυση κακόβουλου λογισμικού.



Εικόνα 1: Δημιουργία εικονικής μηχανής (sandbox)



Εικόνα 2: Απενεργοποιούμε ότι antivirus έχει ο υπολογιστής για να σιγουρευτούμε ότι το κακόβουλο λογισμικό μπορεί να δουλέψει άφοβα.

2. Παρακολούθηση Δικτυακής Κίνησης

Η παρακολούθηση δικτυακής κίνησης είναι μια πολύ βασική τεχνική ανάλυσης. Στόχος της είναι να εντοπίσει και να αναλύσει την κίνηση δικτύου με στόχο να αποκαλύψει ύποπτες κινήσεις, οι οποίες θα υποδηλώνουν κακόβουλη δραστηριότητα όπως είναι η κλοπή δεδομένων, η επικοινωνία με botnets ή λήψη παραπάνω κακόβουλου λογισμικού. Αυτή η διαδικασία συχνά βασίζεται σε συστήματα ανίχνευσης εισβολών (IDS) και συστήματα πρόληψης εισβολών (IPS), τα οποία αναλύουν την κυκλοφορία δικτύου σε πραγματικό χρόνο και αναζητούν μοτίβα που ταιριάζουν με γνωστές απειλές.

Αυτή η τεχνική μπορεί να περιλαμβάνει μια ποικιλία ενεργειών, από απλές επιθεωρήσεις αρχείων καταγραφής, έως και πιο σύνθετες αναλύσεις συμπεριφοράς

δικτύου, όμως σε γενικές γραμμές, η διαδικασία παρακολούθησης δικτυακής κίνησης περιλαμβάνει τα εξής βήματα:

Βήμα 1. Εκτέλεση του δείγματος σε ελεγχόμενο περιβάλλον: Για να αποφευχθεί η μόλυνση του πραγματικού συστήματος, η εκτέλεση γίνεται σε εικονική μηχανή ή σε sandbox.

Βήμα 2. Συλλογή δικτυακής κίνησης: Εργαλεία παρακολούθησης, όπως tcpdump, Wireshark, ή Network Monitor, καταγράφουν όλα τα πακέτα δεδομένων που αποστέλλονται και λαμβάνονται από το υποπύλο αρχείο.

Βήμα 2. Ανάλυση δικτυακής κίνησης: Τα συλλεχθέντα δεδομένα αναλύονται για να εντοπιστούν ύποπτες συμπεριφορές, όπως:

- Συνδέσεις με ύποπτες διευθύνσεις IP ή domains
- Χρήση ύποπτων πρωτοκόλλων
- Μεταφορά δεδομένων σε μη κρυπτογραφημένη μορφή
- Μοτίβα επικοινωνίας που υποδηλώνουν botnet δραστηριότητα

Βήμα 3. Συσχέτιση με άλλες δυναμικές αναλύσεις: Τα ευρήματα από την παρακολούθηση δικτυακής κίνησης συχνά συνδυάζονται με πληροφορίες από άλλες δυναμικές μεθόδους ανάλυσης, όπως η παρακολούθηση κλήσεων API ή αλλαγών στο σύστημα αρχείων, για να σχηματιστεί μια ολοκληρωμένη εικόνα της συμπεριφοράς του λογισμικού.

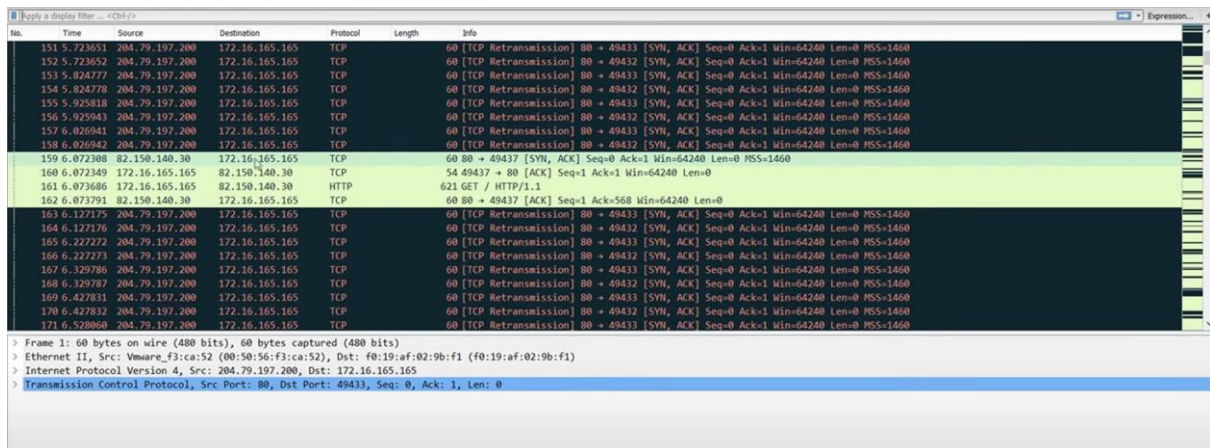
Πλεονεκτήματα τεχνικής:

- Αποκάλυψη επικοινωνίας με botnets
- Εντοπισμός κλοπής δεδομένων
- Συσχέτιση με απειλές zero-day
- Ενδείξεις για τρωτότητες

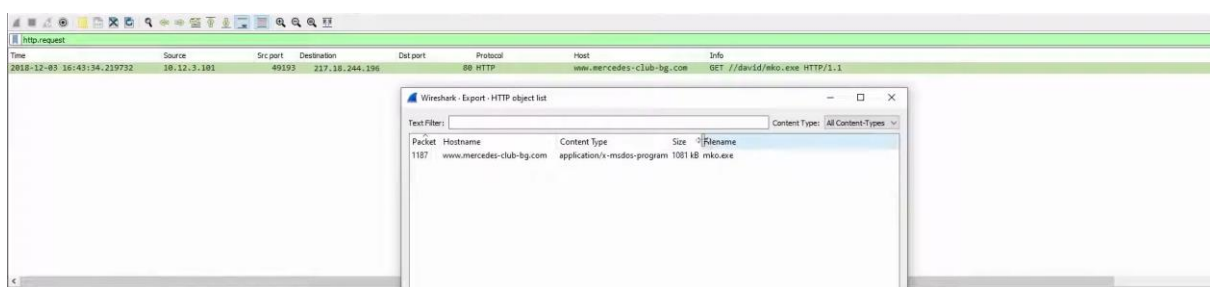
Προκλήσεις τεχνικής:

- Κρυπτογράφηση δικτύου: Η ανάλυση δυσχεραίνεται όταν η επικοινωνία του λογισμικού είναι κρυπτογραφημένη.
- Δυναμική DNS: Η χρήση δυναμικών DNS μπορεί να δυσκολέψει την ταυτοποίηση των servers με τους οποίους επικοινωνεί το λογισμικό.

Παρακάτω βλέπουμε φωτογραφίες μιας μικρής προσομοίωσης αυτής της μεθόδου.



Εικόνα 3: Χρήση του εργαλείου wireshark για παρακολούθηση δικτυακής κίνησης



Εικόνα 4: Βλέπουμε το κακόβουλο αρχείο που κατεβάσαμε από μια ιστοσελίδα

Στην Εικόνα 4, καταλαβαίνουμε ότι είναι κακόβουλο αρχείο, αφού είναι το μόνο πράγμα που κατέβηκε από την σελίδα και έγινε χωρίς να το ξέρουμε (δεν θα το ξέραμε αν δεν το βλέπαμε με κάποιο εργαλείο όπως το wireshark)

3. Παρακολούθηση Αλλαγών στο Σύστημα Αρχείων

Η παρακολούθηση αλλαγών στο σύστημα αρχείων είναι μια κρίσιμη τεχνική της δυναμικής ανάλυσης κακόβουλου λογισμικού. Στόχος είναι να καταγράψουμε και να ερμηνεύσουμε τις τροποποιήσεις που κάνει ένα ύποπτο αρχείο στο σύστημα αρχείων κατά την εκτέλεσή του. Οι βασικοί λόγοι που καθιστούν σημαντική την παρακολούθηση αλλαγών στο σύστημα αρχείων είναι:

- Εντοπισμός εγκατάστασης κακόβουλου λογισμικού: Συχνά, το κακόβουλο λογισμικό τροποποιεί το σύστημα αρχείων για να εγκατασταθεί μόνιμα στο σύστημα, π.χ. αντιγράφοντας τον εαυτό του σε συγκεκριμένους φακέλους ή δημιουργώντας νέα αρχεία για την αποθήκευση δεδομένων ή ρυθμίσεων.
- Αναγνώριση κλοπής δεδομένων
- Κατανόηση τρόπου λειτουργίας
- Ανίχνευση δημιουργίας backdoors

Η διαδικασία παρακολούθησης αλλαγών στο σύστημα αρχείων ακολουθεί τα παρακάτω βήματα:

Βήμα 1.Εκτέλεση σε ελεγχόμενο περιβάλλον: Όπως και με άλλες δυναμικές μεθόδους ανάλυσης, η εκτέλεση του ύποπτου αρχείου γίνεται σε εικονική μηχανή ή sandbox (όπως συζητήσαμε και προηγουμένως) για να αποτραπεί οποιαδήποτε ζημιά στο πραγματικό σύστημα.

Βήμα 2.Χρήση εργαλείων παρακολούθησης: Υπάρχουν εξειδικευμένα εργαλεία για την παρακολούθηση αλλαγών στο σύστημα αρχείων, όπως το Procmon από την Sysinternals Suite ή το FileMon. Αυτά τα εργαλεία καταγράφουν όλες τις προσβάσεις και τροποποιήσεις σε αρχεία και φακέλους, συμπεριλαμβανομένων πληροφοριών όπως το όνομα του αρχείου, η ενέργεια (π.χ. δημιουργία, ανάγνωση, εγγραφή), η χρονική σήμανση και η διεργασία που πραγματοποίησε την ενέργεια.

Βήμα 3.Ερμηνεία των αλλαγών

Πλεονεκτήματα τεχνικής:

- Ακριβής καταγραφή: Τα εργαλεία παρακολούθησης παρέχουν λεπτομερή καταγραφή όλων των ενεργειών που σχετίζονται με το σύστημα αρχείων.
- Εύκολη ανάλυση
- Συνεργασία με άλλες τεχνικές

Προκλήσεις τεχνικής:

- False alarms: Ενδέχεται, φυσιολογικές αλλαγές, να γίνει λάθος και να εκληφθούν ως ενέργειες κακόβουλου λογισμικού.
- Πολυπλοκότητα Κακόβουλων Λογισμικών: Πολλά κακόβουλα λογισμικά είναι πολύ εξελιγμένα, όπου μπορεί να κρύβονται και να μην ανιχνεύεται.

4. Ανίχνευση Κλήσεων API και Χρήσης Εντολών

Η μέθοδος αυτή βασίζεται στην παρακολούθηση των συγκεκριμένων λειτουργιών του λειτουργικού συστήματος, που καλεί ένα ύποπτο πρόγραμμα, καθώς και των εντολών που εκτελεί. Η ανάλυση του τρόπου και της σειράς με την οποία ένα πρόγραμμα χρησιμοποιεί API και εντολές μπορεί να αποκαλύψει πολύτιμες πληροφορίες σχετικά με τη συμπεριφορά του, συμπεριλαμβανομένων και των κακόβουλων δραστηριοτήτων.

Κλήσεις API:

Τα API (Application Programming Interfaces) είναι ένα σύνολο προκαθορισμένων εντολών και πρωτοκόλλων, που παρέχουν πρόσβαση σε λειτουργίες του λειτουργικού συστήματος. Για παράδειγμα, ένα πρόγραμμα μπορεί να χρησιμοποιήσει API για να διαβάσει ή να γράψει σε ένα αρχείο, να δημιουργήσει

μια σύνδεση δικτύου, ή να τροποποιήσει τη κεντρική βάση δεδομένων (registry) του συστήματος.

Η παρακολούθηση των κλήσεων API μπορεί να βοηθήσει στην:

- Αναγνώριση τυπικών μοτίβων κακόβουλης συμπεριφοράς:
Ορισμένες κλήσεις API χρησιμοποιούνται συχνά από κακόβουλο λογισμικό για την πραγματοποίηση συγκεκριμένων ενεργειών.
- Κατανόηση σκοπού και λειτουργικότητας
- Ανίχνευση προσπαθειών zero-day
- Ταξινόμηση κακόβουλου λογισμικού

Χρήση εντολών:

Εκτός από τις κλήσεις API, η παρακολούθηση των εντολών που εκτελεί ένα πρόγραμμα μπορεί να προσφέρει πολύτιμα στοιχεία για την ανάλυση. Παραδείγματα τέτοιων εντολών είναι:

- Εντολές shell
- Εντολές scripting

Η ανίχνευση της χρήσης τέτοιων εντολών από κακόβουλο λογισμικό μπορεί να αποκαλύψει:

- Τεχνικές απόκρυψης
- Λήψη επιπλέον κακόβουλου κώδικα
- Εκτέλεση κακόβουλων scripts

Εργαλεία και τεχνικές:

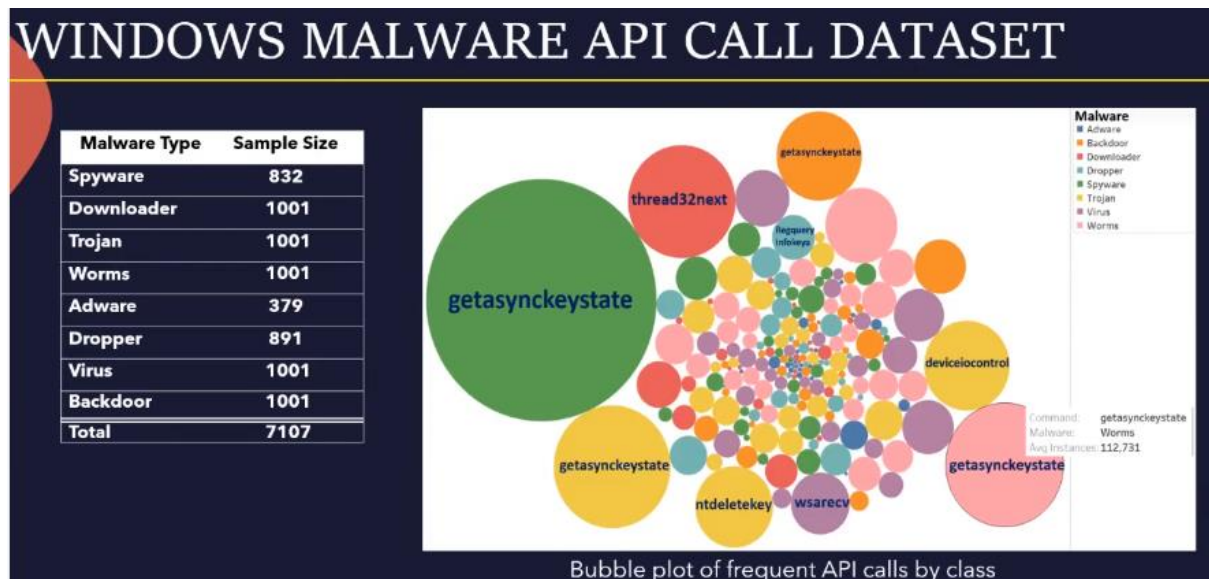
Για την ανίχνευση κλήσεων API και χρήσης εντολών υπάρχουν διάφορα εργαλεία και τεχνικές:

- API hooking: Η τεχνική αυτή επιτρέπει την παρεμβολή στις κλήσεις API, καταγράφοντας τα ορίσματα που δίνονται σε κάθε κλήση, καθώς και την τιμή που επιστρέφεται.
- Debuggers

- Dynamic Binary Instrumentation (DBI)
- Hardware-assisted virtualization

Προκλήσεις:

- Αντι-ανίχνευση
- Πολυμορφισμός
- Κρυπτογράφηση κώδικα



Εικόνα 5: Πιο διάσημα API calls Bubble diagram

5. Ανάλυση Συμπεριφοράς Μνήμης

Η μέθοδος αυτή, επικεντρώνεται στην εξέταση του τρόπου, με τον οποίο το κακόβουλο λογισμικό αλληλοεπιδρά, με τη μνήμη του συστήματος. Κατά την εκτέλεση, ένα πρόγραμμα φορτώνει δεδομένα στη μνήμη, εκτελεί εντολές και τροποποιεί τιμές. Η παρακολούθηση αυτών των ενεργειών μπορεί να προσφέρει πολύτιμες πληροφορίες σχετικά με:

- Τις τεχνικές που χρησιμοποιεί το πρόγραμμα για την απόκρυψη ή την έγχυση κακόβουλου κώδικα.
- Τις δομές δεδομένων που χρησιμοποιεί και τον τρόπο με τον οποίο χειρίζεται τα δεδομένα.
- Τις επικοινωνίες του προγράμματος με άλλες διεργασίες ή με το δίκτυο.

Τεχνικές Ανάλυσης Συμπεριφοράς Μνήμης:

- Memory Dumping: Η τεχνική αυτή περιλαμβάνει τη δημιουργία ενός στιγμιότυπου (snapshot) της μνήμης του συστήματος κατά τη διάρκεια εκτέλεσης του ύποπτου προγράμματος. Στη συνέχεια, το στιγμιότυπο αυτό μπορεί να αναλυθεί offline για να εντοπιστούν ύποπτες περιοχές μνήμης, κρυπτογραφημένα δεδομένα, ή ίχνη κακόβουλου κώδικα.
- Memory Forensics: Η ιατροδικαστική ανάλυση μνήμης (Memory Forensics) επεκτείνει την τεχνική του memory dumping, εστιάζοντας στην εξαγωγή ιατροδικαστικών στοιχείων από τη μνήμη, όπως timestamps, loaded modules, και network connections.
- Dynamic Memory Analysis: Η δυναμική ανάλυση μνήμης περιλαμβάνει την παρακολούθηση των προσβάσεων και των τροποποιήσεων στη μνήμη κατά τη διάρκεια εκτέλεσης του προγράμματος. Εργαλεία όπως τα debuggers και τα memory scanners μπορούν να χρησιμοποιηθούν για να παρακολουθούνται read, write, και execute operations σε συγκεκριμένες περιοχές μνήμης.
- Code Injection Detection: Η τεχνική αυτή εστιάζει στην ανίχνευση κακόβουλου κώδικα που έχει εγχυθεί στη μνήμη άλλων διεργασιών. Η ανάλυση συμπεριφοράς μνήμης μπορεί να χρησιμοποιηθεί για να εντοπιστούν αλλοίωση μνήμης, ύποπτα memory allocations, και ύποπτα threads που εκτελούν τον εγχυμένο κώδικα.
- Malware Unpacking: Πολλά κακόβουλα προγράμματα χρησιμοποιούν τεχνικές συσκευασίας (packing) για να κρυπτογραφήσουν ή να συμπιέσουν τον κώδικά τους. Η ανάλυση συμπεριφοράς μνήμης μπορεί να βοηθήσει στον εντοπισμό του σημείου όπου ο κώδικας αποσυσκευάζεται (unpack) στη μνήμη, επιτρέποντας την περαιτέρω ανάλυση του αποσυσκευασμένου κώδικα.

Εργαλεία και Τεχνολογίες:

- Debuggers: Debuggers όπως το OllyDbg και το Immunity Debugger επιτρέπουν τον έλεγχο της εκτέλεσης του προγράμματος βήμα προς βήμα, καθώς και την παρακολούθηση των τιμών στη μνήμη.
- Memory Scanners: Εργαλεία όπως το Cheat Engine και το Process Hacker επιτρέπουν την σάρωση της μνήμης για συγκεκριμένες τιμές ή μοτίβα.

- Memory Analysis Frameworks: Υπάρχουν εξειδικευμένα frameworks για την ανάλυση μνήμης, όπως το Volatility Framework και το Rekall, που προσφέρουν εργαλεία για memory dumping, memory forensics, και ανάλυση memory structures.
- Dynamic Binary Instrumentation (DBI): Εργαλεία DBI όπως το Pin και το DynamoRIO επιτρέπουν την τροποποίηση του κώδικα κατά την εκτέλεση, προσθέτοντας instrumentation για την παρακολούθηση προσβάσεων στη μνήμη.
- Hardware-assisted Virtualization: Τεχνολογίες virtualization όπως το Intel VT-x και το AMD-V μπορούν να χρησιμοποιηθούν για την δημιουργία εικονικών μηχανών με υποστήριξη για hardware breakpoints, διευκολύνοντας την παρακολούθηση προσβάσεων στη μνήμη.

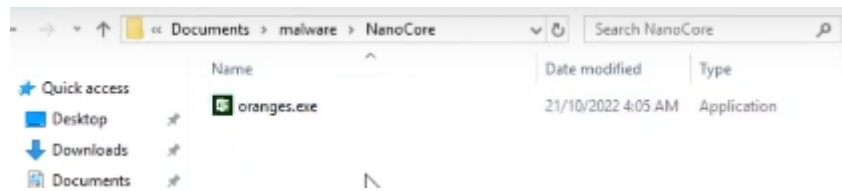
Προκλήσεις τεχνικής:

- Anti-Debugging Techniques: Κακόβουλο λογισμικό μπορεί να χρησιμοποιεί τεχνικές anti-debugging για να αποτρέψει την ανάλυση μνήμης.
- Memory Encryption: Κρυπτογράφηση δεδομένων στη μνήμη μπορεί να δυσκολέψει την ανάλυση.
- Code Obfuscation: Τεχνικές obfuscation μπορούν να αλλάξουν τον κώδικα και να δυσκολέψουν την ανάλυση συμπεριφοράς μνήμης.
- Large Memory Spaces: Σύγχρονα συστήματα έχουν μεγάλη μνήμη RAM, γεγονός που μπορεί να καθυστερήσει την ανάλυση.

Παράδειγμα με χρήση επίθεσης NanoCore Trojan:



Εικόνα 6: Παίρνουμε τις καταγραφές μνήμης μία πριν την επίθεση και μία μετά. (Τα dmp files)



Εικόνα 7: Το όνομα του κακόβουλου λογισμικού που θα τρέξουμε.

3616	552	svchost.exe	0xa704ad84b080	3	-	0	False	2022-10-21 02:02:43.000000	N/A	Disabled
3884	552	svchost.exe	0xa704ac34c080	2	-	0	False	2022-10-21 02:06:50.000000	N/A	Disabled
3292	552	svchost.exe	0xa704ad914540	5	-	0	False	2022-10-21 02:06:56.000000	N/A	Disabled
4140	752	WindowsInterna	0xa704ad26d080	27	-	1	False	2022-10-21 02:08:14.000000	N/A	Disabled
6744	552	MsMpEng.exe	0xa704ac5f6080	15	-	0	False	2022-10-21 02:08:18.000000	N/A	Disabled
4792	552	svchost.exe	0xa704ae325080	7	-	0	False	2022-10-21 02:08:43.000000	N/A	Disabled
2316	752	WmiPrivSE.exe	0xa704adc06080	8	-	0	False	2022-10-21 02:10:45.000000	N/A	Disabled
7080	552	svchost.exe	0xa704adcf2500	6	-	0	False	2022-10-21 02:52:40.000000	N/A	Disabled
4932	1644	audiolog.exe	0xa704a8652080	4	-	0	False	2022-10-21 02:52:42.000000	N/A	Disabled
8592	552	svchost.exe	0xa704ac318080	2	-	0	False	2022-10-21 02:52:44.000000	N/A	Disabled
5560	752	backgroundTask	0xa704aa155080	34	-	1	False	2022-10-21 02:52:45.000000	N/A	Disabled
3404	752	SecHealthUI.ex	0xa704aea44240	28	-	1	False	2022-10-21 02:52:54.000000	N/A	Disabled
3180	752	dllhost.exe	0xa704aecb33c0	5	-	0	False	2022-10-21 02:52:59.000000	N/A	Disabled
5688	552	svchost.exe	0xa704ad0b080	4	-	0	False	2022-10-21 02:54:31.000000	N/A	Disabled
9012	552	svchost.exe	0xa704aea422c0	3	-	0	False	2022-10-21 02:54:51.000000	N/A	Disabled
4624	4404	notepad.exe	0xa704ac657080	1	-	1	False	2022-10-21 04:04:15.000000	N/A	Disabled
9556	752	MicrosoftEdgeC	0xa704acfec080	47	-	1	False	2022-10-21 04:04:40.000000	N/A	Disabled
9648	752	MicrosoftEdgeC	0xa704aee22480	38	-	1	False	2022-10-21 04:04:41.000000	N/A	Disabled
9776	6236	Windows.WARP.J	0xa704aee280c0	4	-	0	False	2022-10-21 04:04:42.000000	N/A	Disabled
9864	6236	Windows.WARP.J	0xa704aef9b080	5	-	0	False	2022-10-21 04:04:42.000000	N/A	Disabled
3016	752	MicrosoftEdgeC	0xa704aca63080	15	-	1	False	2022-10-21 04:05:00.000000	N/A	Disabled
7764	5068	SearchFilterHo	0xa704ad384540	5	-	0	False	2022-10-21 04:05:09.000000	N/A	Disabled
10216	752	RuntimeBroker	0xa704ae25f300	8	-	1	False	2022-10-21 04:05:15.000000	N/A	Disabled
1108	752	RuntimeBroker	0xa704ad91d080	12	-	1	False	2022-10-21 04:05:22.000000	N/A	Disabled
9240	5068	SearchProtocol	0xa704ae762080	6	-	0	False	2022-10-21 04:05:26.000000	N/A	Disabled
8468	752	MicrosoftEdgeC	0xa704ad4d3080	0	-	1	False	2022-10-21 04:05:27.000000	2022-10-21 04:05:29.000000	Disabled
3092	752	MicrosoftEdgeC	0xa704ad7c5080	15	-	1	False	2022-10-21 04:05:43.000000	N/A	Disabled
10160	7652	mscorsv.exe	0xa704ad7c5080	9	-	0	True	2022-10-21 04:06:12.000000	N/A	Disabled
7236	4404	oranges.exe	0xa704a8080080	11	-	1	True	2022-10-21 04:06:13.000000	N/A	Disabled
4596	4404	DumpIt.exe	0xa704ae08e080	5	-	1	False	2022-10-21 04:06:21.000000	N/A	Disabled
7976	4596	conhost.exe	0xa704aca1e080	5	-	1	False	2022-10-21 04:06:21.000000	N/A	Disabled

Εικόνα 8: Βλέπουμε το memory dump μετά από την επίθεση και βλέπουμε ότι υπάρχει το κακόβουλο αρχείο.

Εδώ μπορούμε να συνεχίσουμε να κάνουμε κι άλλη ανάλυση αλλά είναι εκτός του θέματος της εργασίας.

6. Reverse Debugging (Ανάλυση Αντίστροφης Εκτέλεσης)

Η ανάλυση αντίστροφης εκτέλεσης, στοχεύει στην κατανόηση της λειτουργίας ενός προγράμματος με την αποκωδικοποίηση και την ανάλυση του κώδικά του. Ουσιαστικά, η μέθοδος αυτή προσπαθεί να "γυρίσει πίσω" τη διαδικασία ανάπτυξης λογισμικού, μετατρέποντας τον εκτελέσιμο κώδικα σε μια πιο κατανοητή μορφή. Η ανάλυση αντίστροφης εκτέλεσης μπορεί να αποκαλύψει σημαντικές πληροφορίες για το κακόβουλο λογισμικό, όπως:

- Τον σκοπό και τη λειτουργία του προγράμματος.
- Τις τεχνικές που χρησιμοποιεί για να αποκρύψει τον κακόβουλο κώδικά του.
- Τις μεθόδους επικοινωνίας με τον δημιουργό του ή με άλλα συστήματα.
- Τις ευπάθειες που ενδεχομένως εκμεταλλεύεται.

Βήματα στην ανάλυση αντίστροφης εκτέλεσης:

Βήμα 1. Αποκωδικοποίηση (Disassembly): Μετατροπή του εκτελέσιμου κώδικα σε assembly code, μια συμβολική αναπαράσταση των εντολών του επεξεργαστή.

Βήμα 2. Στατική ανάλυση κώδικα: Εξέταση του assembly code για τον εντοπισμό συναρτήσεων, δομών δεδομένων, αλγορίθμων και άλλων χαρακτηριστικών του προγράμματος.

Βήμα 3. Δυναμική ανάλυση: Εκτέλεση του προγράμματος σε ελεγχόμενο περιβάλλον (sandbox) ή με τη χρήση debugger, για την παρακολούθηση της συμπεριφοράς του και τον εντοπισμό ύποπτων ενεργειών.

Βήμα 4. Αποκρυπτογράφηση: Εάν ο κώδικας έχει κρυπτογραφηθεί, η ανάλυση αντίστροφης εκτέλεσης περιλαμβάνει την εύρεση του κλειδιού αποκρυπτογράφησης και την αποκάλυψη του πραγματικού κώδικα.

Βήμα 5. Ανακατασκευή κώδικα: Μετά την ανάλυση του assembly code, μπορεί να γίνει προσπάθεια για την ανακατασκευή του κώδικα σε μια γλώσσα υψηλού επιπέδου (π.χ. C, C++), για να γίνει πιο κατανοητός.

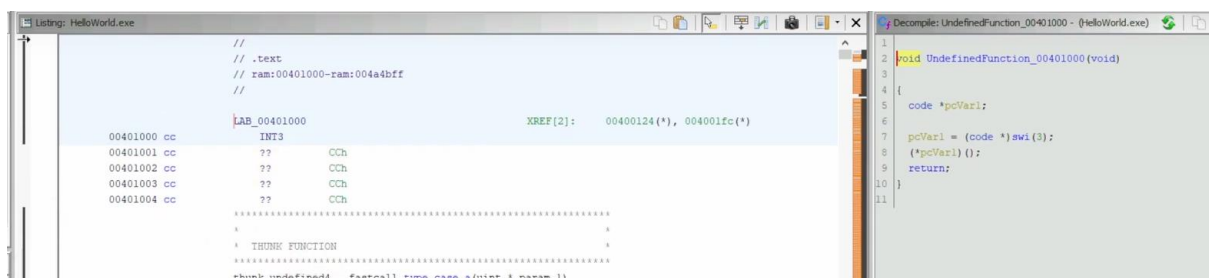
Εργαλεία ανάλυσης αντίστροφης εκτέλεσης:

- Disassemblers όπως IDA Pro, Ghidra, Radare2
- Debuggers όπως OllyDbg, Immunity Debugger, xdb64
- Hex Editors όπως HxD, 010 Editor
- Decompilers όπως Hex-Rays Decompiler, Snowman Decompiler
- Sandbox Environments όπως Cuckoo Sandbox, REMnux

Προκλήσεις Τεχνικής:

- Σύνθετες τεχνικές απόκρυψης: Πολύ κακόβουλο λογισμικό χρησιμοποιεί εξελιγμένες τεχνικές obfuscation και packing, που δυσκολεύουν την ανάλυση.
- Anti-Debugging techniques: Ορισμένα κακόβουλα προγράμματα ενσωματώνουν anti-debugging μηχανισμούς, που εμποδίζουν την ανάλυση με debuggers.
- Χρόνος και πόροι: Η ανάλυση αντίστροφης εκτέλεσης είναι μια χρονοβόρα διαδικασία που απαιτεί εξειδικευμένες γνώσεις και ισχυρό hardware.

Παράδειγμα:



Εικόνα 9: Ο κώδικας υψηλού επιπέδου (που πιθανό να είναι «ψεύτικος») είναι στα δεξιά και με την αποκωδικοποίηση βλέπουμε στα αριστερά τον κώδικα σε assembly.

Εδώ μπορούμε να ψάξουμε στο assembly κώδικα για κάποια συμβολοσειρά που μας κινεί το ενδιαφέρον και επικεντρωνόμαστε σε αυτό.

Εργαλεία

Υπάρχουν πολλά εργαλεία που μπορούμε να χρησιμοποιήσουμε, θα περιγράψουμε μερικά από τα πιο διαδεδομένα εργαλεία:

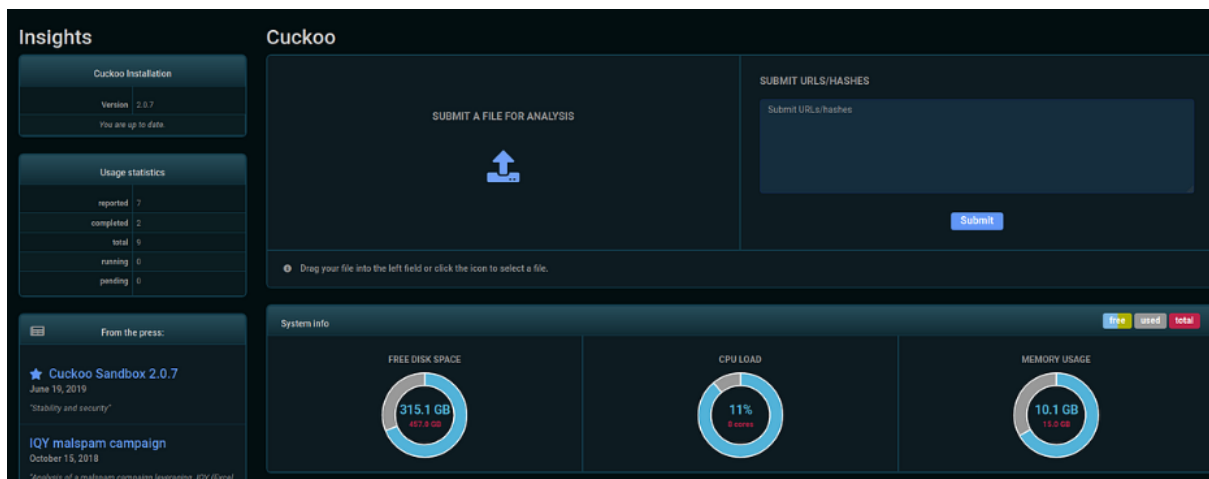
1. Cuckoo Sandbox

Το cuckoo sandbox είναι ένα εργαλείο, που είναι σχεδιασμένο να αυτοματοποιεί όλη τη διαδικασία ανάλυσης κακόβουλου λογισμικού και επιτρέπει την ελεγχόμενη εκτέλεση και παρακολούθηση κακόβουλων αρχείων. Η βασική ιδέα είναι να γίνει όλη η διαδικασία αυτόματα και να παράγει αναφορές με αποτελέσματα χωρίς άμεση ανθρώπινη παρέμβαση. Το μόνο που πρέπει να κάνει ο αναλυτής είναι να υποβάλλει το κακόβουλο λογισμικό και το cuckoo sandbox θα το εκτελέσει σε ελεγχόμενο, απομονωμένο, περιβάλλον.

Το cuckoo sandbox επιστρέφει λεπτομερείς αναφορές για διάφορα χαρακτηριστικά του κακόβουλου λογισμικού, σε μορφή JSON. Εξάγει 2300 χαρακτηριστικά από την δυναμική ανάλυση, ανάμεσα στα οποία είναι:

- Συνοπτικές πληροφορίες
- Αρχεία που δημιουργούνται ή διαγράφονται ή τροποποιούνται
- Κλήσεις API
- Αλλαγές σε κλειδιά στο registry
- IP διευθύνσεις και DNS ερωτήματα
- Προσπελάσεις URL

Αξιοσημείωτο είναι το γεγονός ότι το εργαλείο αυτό είναι ανοικτού κώδικα, άρα δωρεάν, και έχει ακρίβεια 94,64%, που είναι σε γενικές γραμμές καλό. Όμως, πρέπει να σημειωθεί επίσης, ότι εξελιγμένα κακόβουλα λογισμικά μπορούν να καταλάβουν ότι βρίσκονται σε sandbox, αυτό που σχολιάσαμε και πιο πάνω στην εργασία για την μέθοδο sandbox. Επίσης, η δικτυακή ανάλυση είναι ελαφρός περιορισμένη, επομένως έχουμε και εκεί μια «τρύπα».



Εικόνα 10: Διεπαφή του εργαλείου cuckoo sandbox

2. Process Monitor (ProcMon)

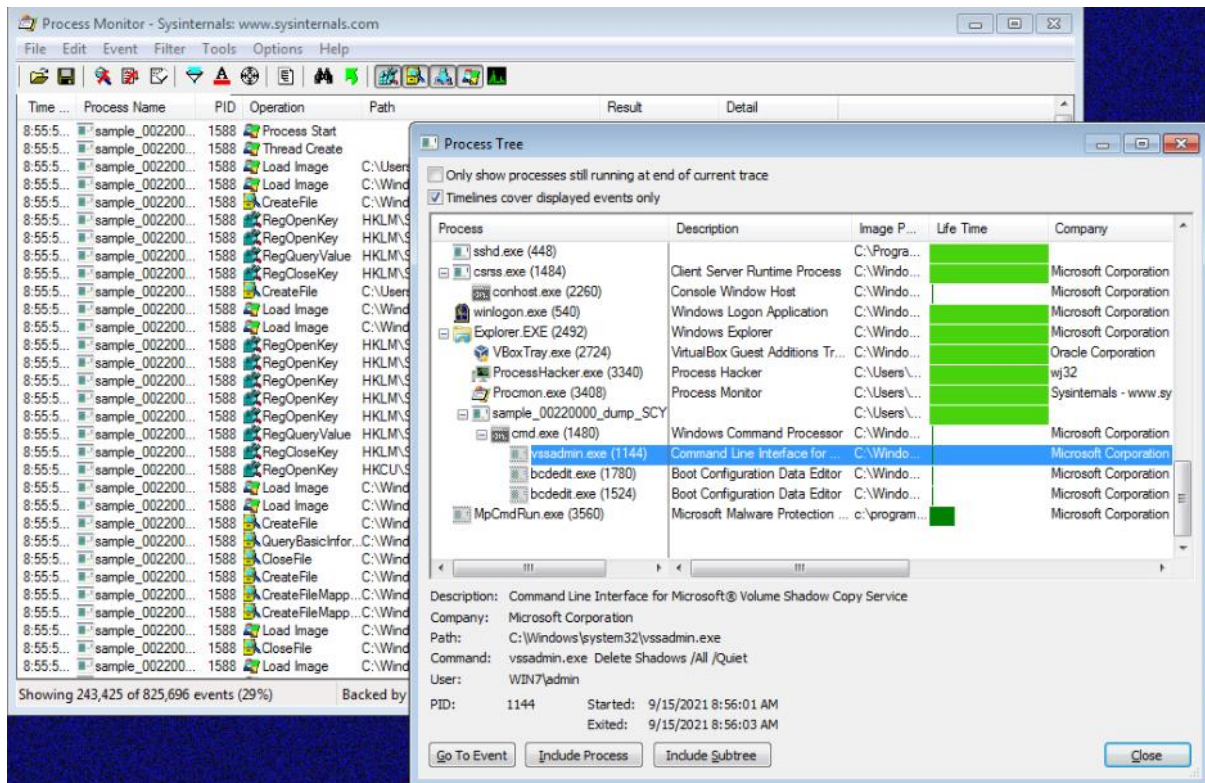
Το Process Monitor είναι ένα εργαλείο της συλλογής Sysinternals που παρέχει πληροφορίες σε πραγματικό χρόνο. Συνδυάζει τις λειτουργίες δύο παλαιότερων εργαλείων, FileMon και RegMon, και είναι σχεδιασμένο να παρακολουθεί τις δραστηριότητες στο σύστημα αρχείων, του registry, των διεργασιών και των threads.

Το ProcMon δίνει λεπτομερή αναφορά για τα συμβάντα που παρακολουθεί, όπως το όνομα της διεργασίας, το PID, τον τύπο λειτουργίας, τη διαδρομή του αρχείου, την ώρα και την ακολουθία συμβάντων. Επίσης, σε συνδυασμό με το παραπάνω, δίνει και την δυνατότητα φιλτραρίσματος πάνω σε όλες αυτές τις λεπτομέρειες κάνοντας έτσι την δουλειά του αναλυτή αρκετά πιο εύκολη.

Αρκετά σημαντικό είναι να σημειωθεί ότι μπορεί να δημιουργήσει ένα δέντρο διεργασιών και να μας δώσει μια πιο γραφική εικόνα του τι γίνεται.

Μερικά επιπλέον χαρακτηριστικά του, είναι:

- Καταγράφει τα αποτελέσματα σε κάποιο αρχείο (πχ. XML ή CSV) ώστε να μπορούν να αναλυθούν σε μελλοντικό χρόνο.
- Δείχνει τα δικαιώματα των διεργασιών, όπως και τα permissions τους.
- Μπορεί να αρχίσει την παρακολούθηση από την εκκίνηση του συστήματος, άρα να βρει και ποιο κακόβουλο λογισμικό ξεκινάει με την εκκίνηση του συστήματος.



Εικόνα 11: Παράδειγμα χρήσης του ProcMon για δημιουργία Process Tree

3. Wireshark

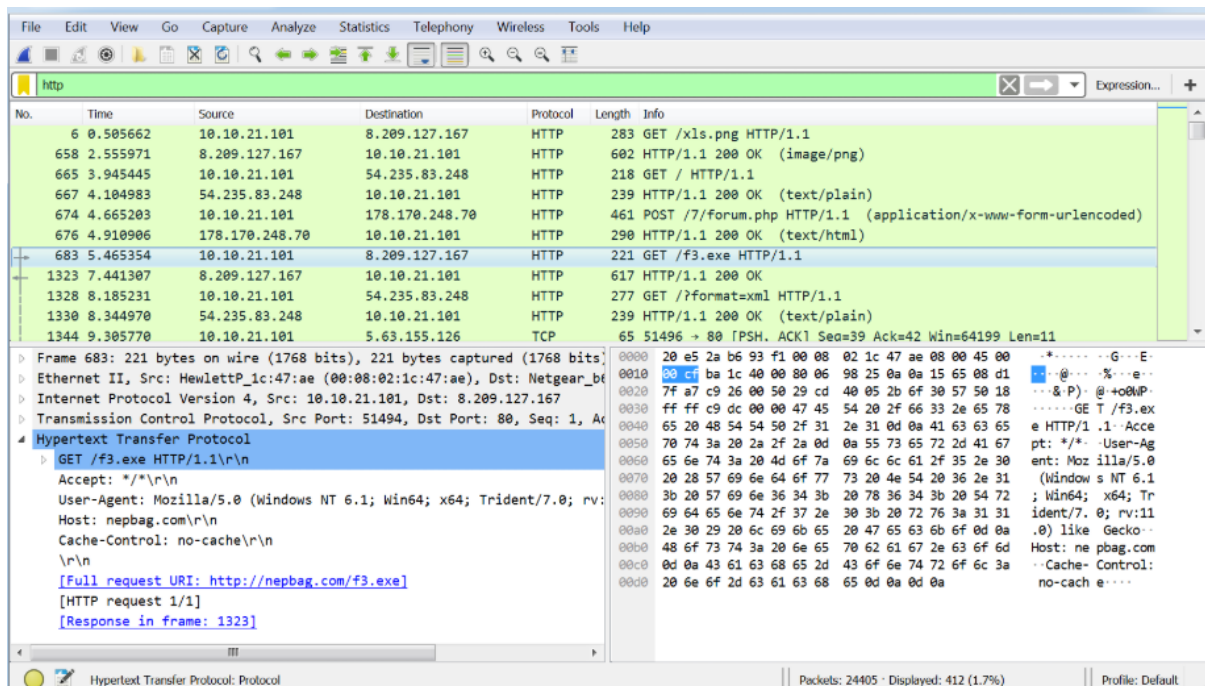
Το Wireshark είναι ίσως το πιο διαδεδομένο εργαλείο για ανάλυση δικτύου. Είναι ανοικτού κώδικα, άρα και δωρεάν, και κάνει καταγραφή και ανάλυση δεδομένων στο δίκτυο.

Καταγράφει πακέτα σε πραγματικό χρόνο και τα αποκωδικοποιεί σε ανθρώπινη γλώσσα για ανάλυση και υποστηρίζει παραπάνω από 850 πρωτόκολλα δικτύου. Επίσης, η γραφική διεπαφή του εργαλείου είναι πολύ εύκολη στην χρήση και υπάρχει η δυνατότητα να γίνει μια «χρωματική κωδικοποίηση» που κάνει πιο εύκολη την ανάλυση, με αποτέλεσμα να είναι ένα εργαλείο που μπορούν μέχρι και νέοι χρήστες να πιάσουν.

Πιο σημαντικά, το wireshark δίνει την δυνατότητα να φιλτράρουμε τις καταγραφές που μας δείχνει το γραφικό περιβάλλον, χρησιμοποιώντας όποια κατηγορία από τα δεδομένα θέλουμε, καθώς και να δημιουργήσουμε δικά μας φίλτρα. Ως δεδομένα απεικονίζει πακέτα, που μεταφέρονται, με πάρα πολλές λεπτομέρειες, όπως και το περιεχόμενο του πακέτου σε δεκαεξαδική και δυαδική μορφή.

Από τα παραπάνω καταλαβαίνουμε ότι αυτό το εργαλείο μπορεί να χρησιμοποιηθεί και για ανάλυση επιθέσεων που έχουν να κάνουν με το δίκτυο,

επομένως μπορούμε να βρούμε ύποπτες κινήσεις πακέτων και έτσι να βρούμε αν πρέπει να διερευνήσουμε κάτι παραπάνω.



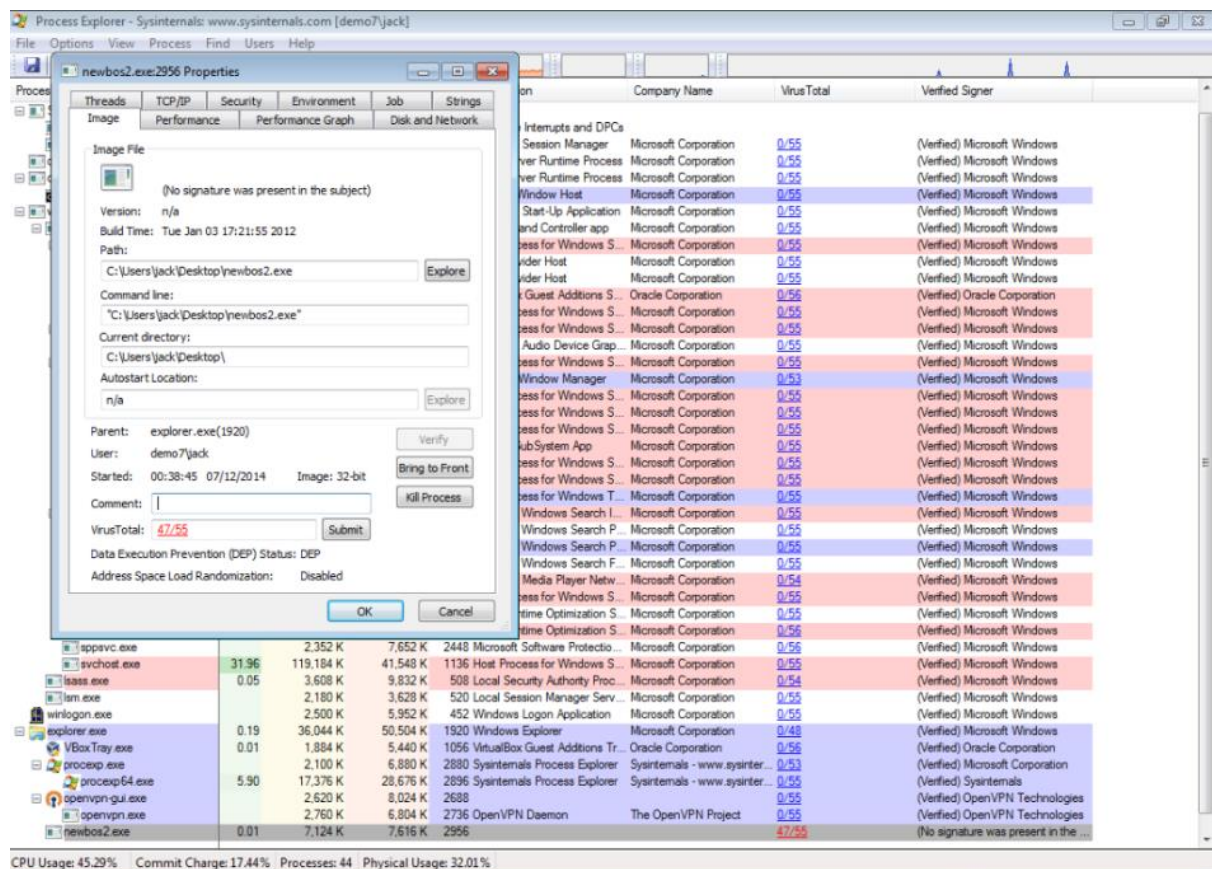
Εικόνα 12: Παράδειγμα διεπαφής wireshark με φίλτρο για πακέτα με το πρωτόκολλο HTTP.

4. Process Explorer

Το Process Explorer είναι και αυτό ένα εργαλείο της συλλογής εργαλείων Sysinternals, και μπορεί να ακούγεται σαν το Process Monitor που αναφέραμε προηγουμένος, κάνουν διαφορετικές καταγραφές. Παρέχει πιο πολλές πληροφορίες από το task manager που γνωρίζουμε όλοι.

Το εργαλείο αυτό επικεντρώνεται στις διεργασίες και στις βιβλιοθήκες που χρησιμοποιούν. Μπορεί δηλαδή να ανιχνεύσει απειλές μέσω κακόβουλων DLL (dynamic link library) που φορτώνουν οι διεργασίες και έτσι να αναδρομικά να καταλάβουμε ποιο είναι το κακόβουλο λογισμικό.

Δεν δίνει πληροφορίες για τα υπόλοιπα στοιχεία που δίνει το Process Monitor, αλλά δίνει πολύ περισσότερη πληροφορία για τις διεργασίες καθώς και τους πόρους που χρησιμοποιούν από το υλικό του υπολογιστικού συστήματος.

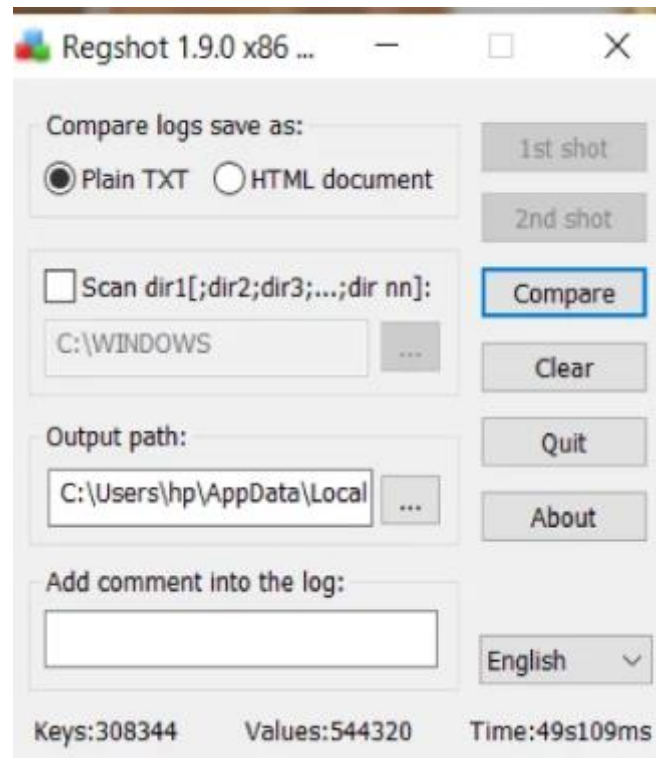


Εικόνα 13: Παράδειγμα κακόβουλου λογισμικού που βρίσκουμε με το εργαλείο Process Explorer

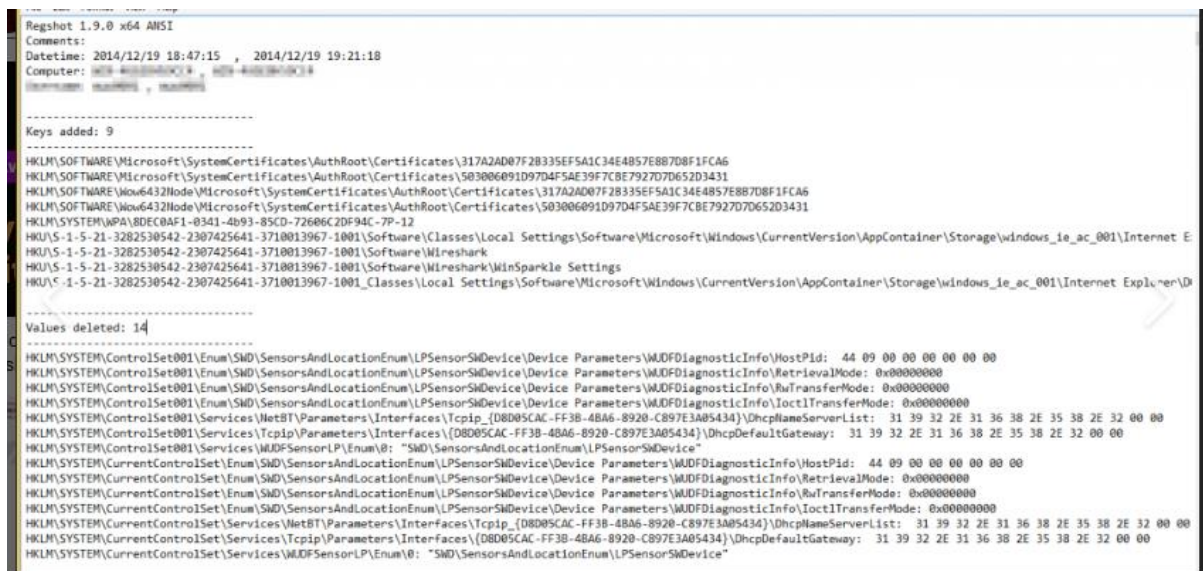
5. Regshot

Το Regshot είναι εργαλείο ανοιχτού κώδικα που είναι σχεδιασμένο για να λαμβάνει στιγμιότυπα του registry και των αρχείων. Ουσιαστικά προσπαθεί ο αναλυτής να εντοπίσει, μέσα από τη σύγκριση στιγμιότυπων, αλλαγές στο registry ή/και στα αρχεία, που είναι ύποπτη, και τις καταγράφει.

Επειδή καταγράφει όλο το registry, απαιτείται εκτενή ανάλυση των αποτελεσμάτων. Έχει γραφική διεπαφή, που το κάνει εύκολο στην χρήση, αλλά η ανάλυση γίνεται μέσω txt ή html αρχείων, πράγμα που κάνει την αυτοματοποίηση του περιορισμένη. Επομένως, είναι ένα δύσκολο στην χρήση εργαλείο.



Εικόνα 14: Γραφικό περιβάλλον regshot



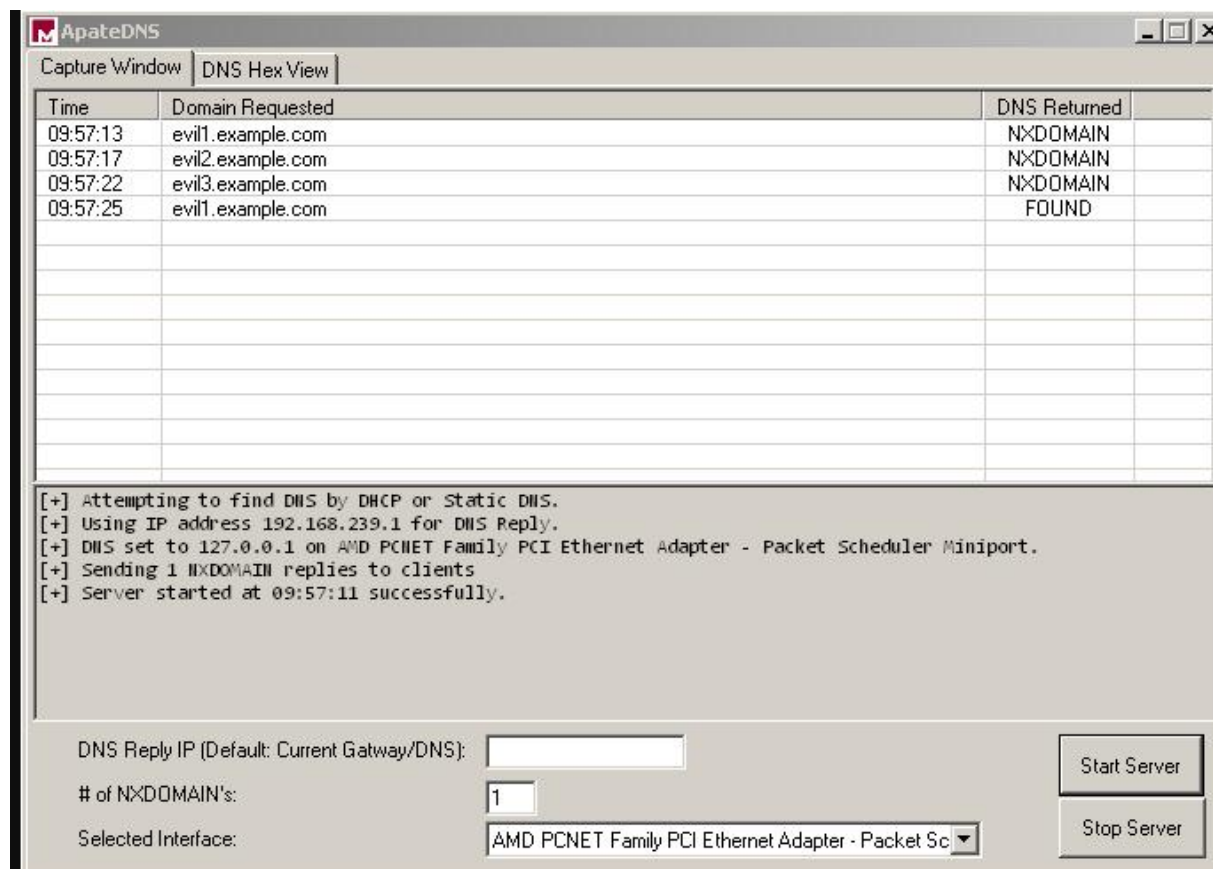
Εικόνα 15: Στιγμιότυπο registry προς ανάλυση

6. ApateDNS

Το ApateDNS, είναι ένα εργαλείο που χρησιμοποιείται ως εικονικός διακομιστής DNS και μας βοηθάει στην ανάλυση κακόβουλου λογισμικού σε ένα δίκτυο. Ως εικονικός διακομιστής, ελέγχει τις ερωτήσεις και τις απαντήσεις DNS, με αποτέλεσμα να δίνει την δυνατότητα οι αναλυτές να παρακολουθούν τις ερωτήσεις που κάνει ένα κακόβουλο λογισμικό.

Το ApateDNS, προσομοιώνει έναν διακομιστή DNS που ακούει από τη θύρα UDP 53 και συλλέγει τα DNS queries που κάνει το κακόβουλο λογισμικό, βοηθώντας έτσι στην βαθύτερη κατανόηση του. Συνήθως συνδυάζεται και με άλλα εργαλεία, για να υπάρξει μια καλύτερη εικόνα του κακόβουλου λογισμικού.

Αφού εξομοιώνει τις απαντήσεις του, πρώτον δημιουργεί ένα απομονωμένο δίκτυο, άρα δεν απαιτείται η σύνδεση στο διαδίκτυο, και ας υπάρχει σύνδεση στο δίκτυο, δεν επηρεάζεται αυτή.

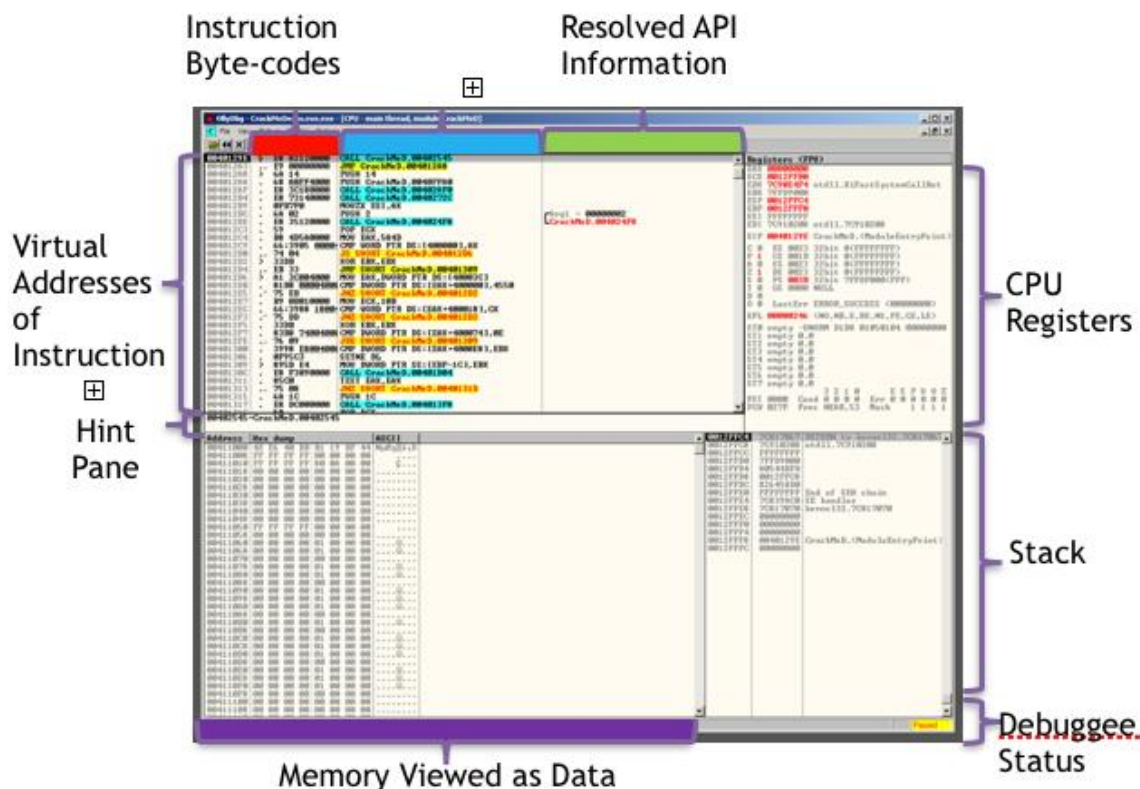


Εικόνα 16: Γραφική διεπαφή ApateDNS.

7. OllyDbg

Το OllyDbg, είναι ένα πολύ διάσημο εργαλείο αντίστροφης μηχανικής. Επιτρέπει στους αναλυτές να παρακολουθούν την εκτέλεση του κώδικα βήμα προς βήμα, να ελέγχουν τις τιμές των registers και να εξετάζουν την μνήμη. Παρέχει μια λεπτομερή εικόνα της συμπεριφοράς ενός εκτελέσιμου αρχείου.

Η εκτέλεση του κώδικα γίνεται σε απομονωμένο περιβάλλον, και η ανάλυση του γίνεται σε πραγματικό χρόνο. Το εργαλείο αυτό, αποκωδικοποιεί τον κώδικα ενός εκτελέσιμου αρχείου, διευκολύνοντας έτσι την κατανόησή του. Επίσης, μας δίνει την δυνατότητα να κάνουμε αναζήτηση κειμένου στον κώδικα, για να ψάχνουμε πιο στοχευμένα.



Εικόνα 17: Γραφική διεπαφή OllyDbg.

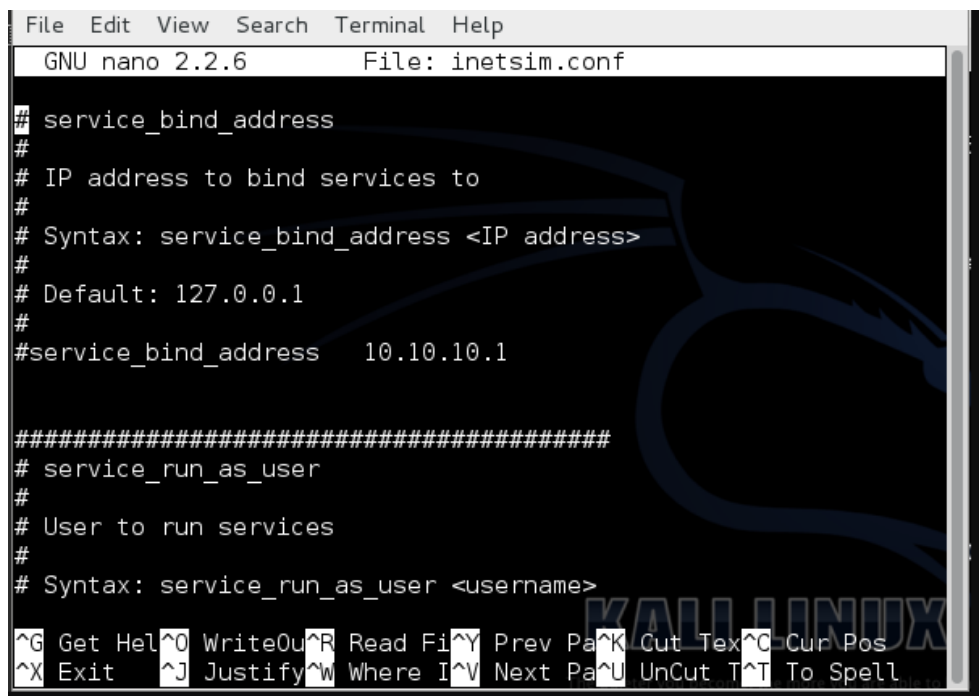
8. INetSim

Το INetSim είναι ένα εργαλείο που σχεδιάστηκε για να μπορεί να προσομοιώνει δικτυακές υπηρεσίες DNS, HTTP κοκ, σε ένα απομονωμένο περιβάλλον ώστε να μπορεί να ξεγελάει το κακόβουλο λογισμικό ότι μιλάει με μια πραγματική οντότητα του δικτύου. Δημιουργεί ψεύτικα αρχεία, ψεύτικες δικτυακές οντότητες, και ότι άλλο χρειαστεί για να εξαπατήσει ένα κακόβουλο λογισμικό. Και αυτό το εργαλείο δουλεύει καλύτερα σε συνδυασμό με άλλα, ώστε να υπάρχει μια πιο πλήρη εικόνα του κακόβουλου λογισμικού.

Η διαμόρφωση των υπηρεσιών του INetSim, διαμορφώνονται από το αρχείο inetsim.conf. Από εκεί ο χρήστης μπορεί να διαμορφώσει ότι χρειαστεί αυτός. Πρέπει να σημειωθεί όμως, ότι το εργαλείο αυτό είναι μόνο για λειτουργικά Linux, πράγμα που το κάνει κάπως απαιτητικό καθώς για να γίνει χρήση του εργαλείου πρέπει να μάθει να χρησιμοποιεί Linux ο χρήστης. (Αν και για μηχανικούς δικτύων και κυβερνοασφάλειας, τα linux είναι αρκετά σημαντικά, πέρα της ανάλυσης κακόβουλου λογισμικού και μπορεί να θεωρούνται δεδομένα)

Το εργαλείο αυτό έχει δύο λειτουργίες:

- Την ψεύτικη λειτουργία: όπου απλά έχει κάποια προκαθορισμένα αρχεία και απαντάει πάντα με αυτά, και είναι ανάλογο μόνο της επέκτασης του αρχείου.
- Την πραγματική λειτουργία: όπου η οντότητα inetsim, απαντάει με τα πραγματικά αρχεία που πηγάζουν από το web root. Επομένως, είναι πιο αληθινή η προσομοίωση.



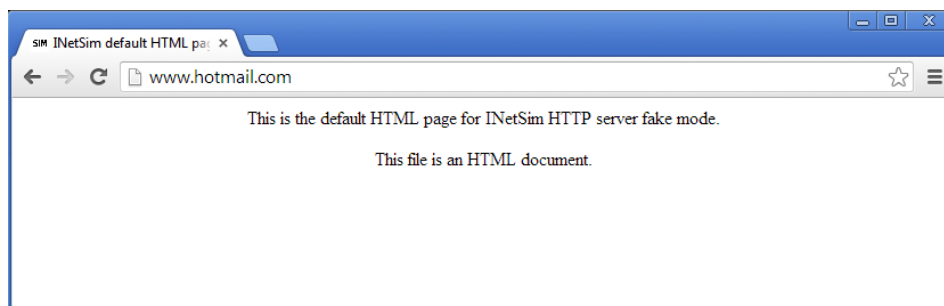
```
File Edit View Search Terminal Help
GNU nano 2.2.6 File: inetsim.conf

# service_bind_address
#
# IP address to bind services to
#
# Syntax: service_bind_address <IP address>
#
# Default: 127.0.0.1
#
#service_bind_address 10.10.10.1

#####
# service_run_as_user
#
# User to run services
#
# Syntax: service_run_as_user <username>

^G Get Hel^O WriteOu^R Read Fi^Y Prev Pa^K Cut Tex^C Cur Pos
^X Exit ^J Justify^W Where I^V Next Pa^U UnCut T^T To Spell
```

Εικόνα 18: inetsim.conf αρχείο διαμόρφωσης

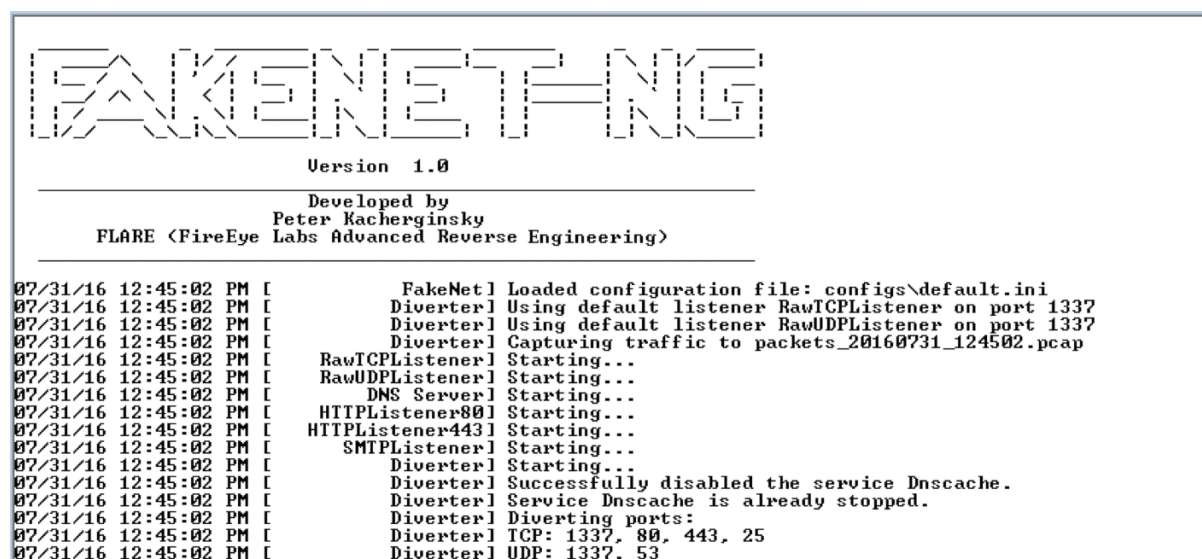


Εικόνα 19: inetsim ψεύτικος ιστότοπος.

9. FakeNet-NG

Βελτιωμένη παραλλαγή του FakeNet. Προσομοιώνει ένα δίκτυο και την κίνηση σε αυτό για την ανάλυση κακόβουλων λογισμικών. Είναι πολύ παρόμοιο με το παραπάνω εργαλείο INetSim, με τις διαφορές ότι:

- Το FakeNet υποστηρίζει και Windows, ενώ το INetSim όχι.
- Πολύ πιο εύκολο στη χρήση, άρα και πιο γρήγορο.
- Δεν μπορεί να προσομοιώσει ρεαλιστικές απαντήσεις, επομένως εύκολα κάποιο κακόβουλο λογισμικό το ξεγελάει.
- Υποστηρίζει περισσότερα πρωτόκολλα, άρα και πιο ευέλικτο.



```

      FAKENET-NG
      Version 1.0

      Developed by
      Peter Kacherginsky
      FLARE <FireEye Labs Advanced Reverse Engineering>

07/31/16 12:45:02 PM [      FakeNet] Loaded configuration file: configs\default.ini
07/31/16 12:45:02 PM [      Diverter] Using default listener RawICPListener on port 1337
07/31/16 12:45:02 PM [      Diverter] Using default listener RawUDPListener on port 1337
07/31/16 12:45:02 PM [      Diverter] Capturing traffic to packets_20160731_124502.pcap
07/31/16 12:45:02 PM [      RawICPListener] Starting...
07/31/16 12:45:02 PM [      RawUDPListener] Starting...
07/31/16 12:45:02 PM [      DNS Server] Starting...
07/31/16 12:45:02 PM [      HTTPListener80] Starting...
07/31/16 12:45:02 PM [      HTTPListener443] Starting...
07/31/16 12:45:02 PM [      SMTPListener] Starting...
07/31/16 12:45:02 PM [      Diverter] Starting...
07/31/16 12:45:02 PM [      Diverter] Successfully disabled the service Dnscache.
07/31/16 12:45:02 PM [      Diverter] Service Dnscache is already stopped.
07/31/16 12:45:02 PM [      Diverter] Diverting ports:
07/31/16 12:45:02 PM [      Diverter] TCP: 1337, 80, 443, 25
07/31/16 12:45:02 PM [      Diverter] UDP: 1337, 53
```

Εικόνα 20: Η διεπαφή fakenet-ng

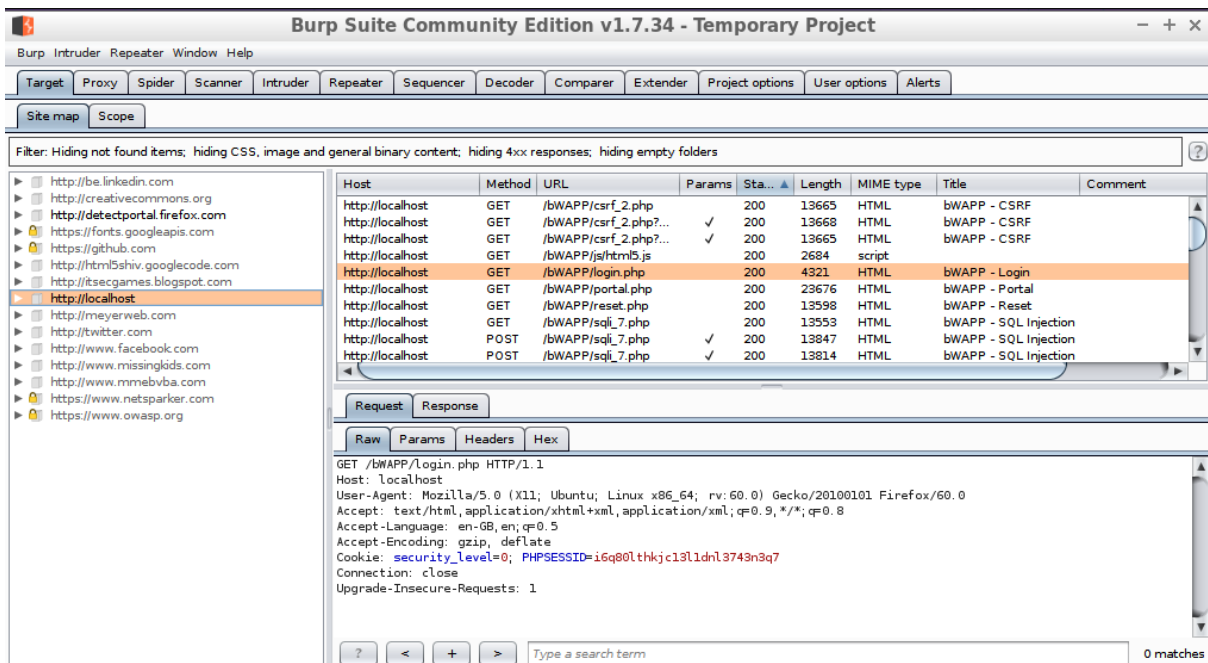
10. Burp Suite

Το Burp Suite, είναι ένα επαγγελματικό λογισμικό (άρα επί πληρωμή), και είναι μια ολοκληρωμένη εργαλειοθήκη ασφαλείας. Παρέχει πολλές λειτουργίες για ανάλυση κακόβουλων λογισμικών και ασφάλειας γενικότερα. Ανιχνεύει κίνηση στο δίκτυο, αποκωδικοποιεί κώδικα και δεδομένα, για διάφορες μορφές κωδικοποίησης. Είναι ουσιαστικά, όλα τα παραπάνω εργαλεία μαζί συν ότι περιέχει επιπλέον modules, που είναι σχεδιασμένα για την ανάλυση και δοκιμή εφαρμογών ιστού. Τα modules αυτά είναι:

- Spider module: ανιχνεύει αυτόματα web εφαρμογές και καταγράφει το περιεχόμενο και την λειτουργία τους
- Scanner module: Αυτόματα βρίσκει κενά ασφάλειας σε εφαρμογές ιστού.
- Intruder module: Επιτρέπει την προσαρμογή και την αυτοματοποίηση επιθέσεων.
- Repeater module: Δίνει την δυνατότητα να τροποποιούνται και να επανυποβάλλονται αιτήματα HTTP για έλεγχο ευπαθειών.

- Decoder module: αποκωδικοποιητής

Το εργαλείο αυτό είναι ένα από τα πιο δυνατά και εύχρηστα εργαλεία ασφάλειας που υπάρχουν.



Εικόνα 21: Γραφική διεπαφή του Burp suite.